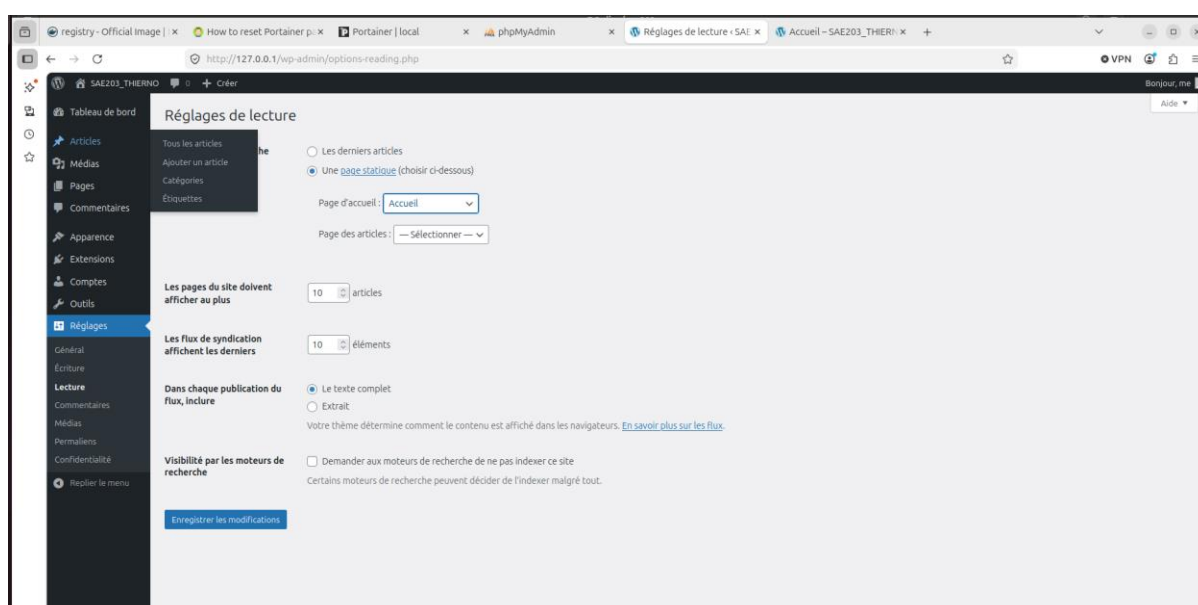
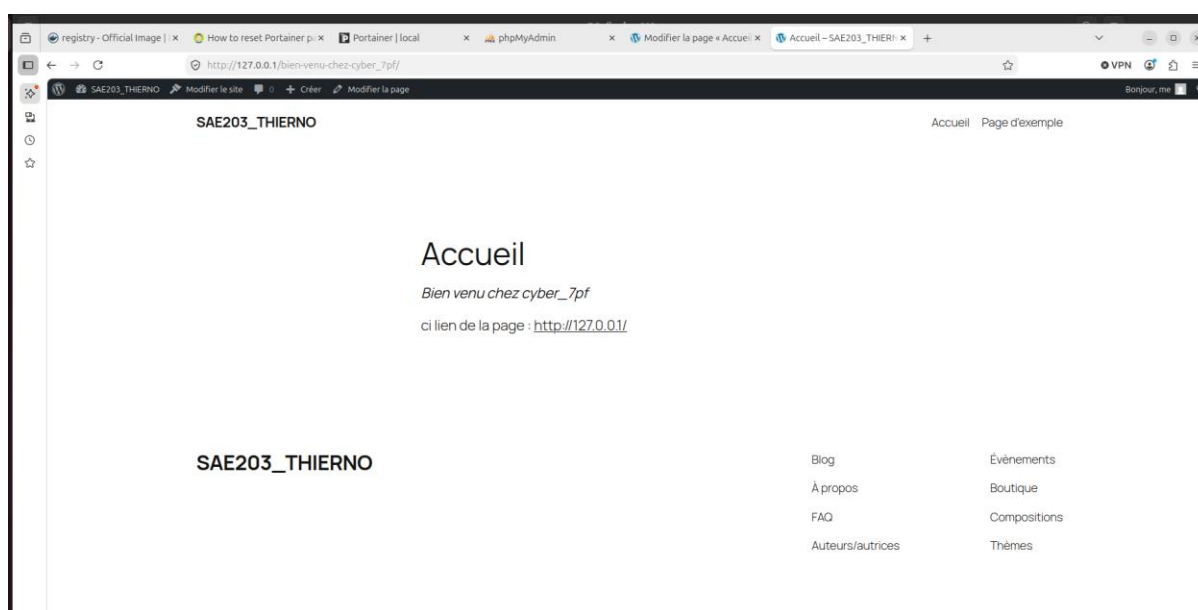


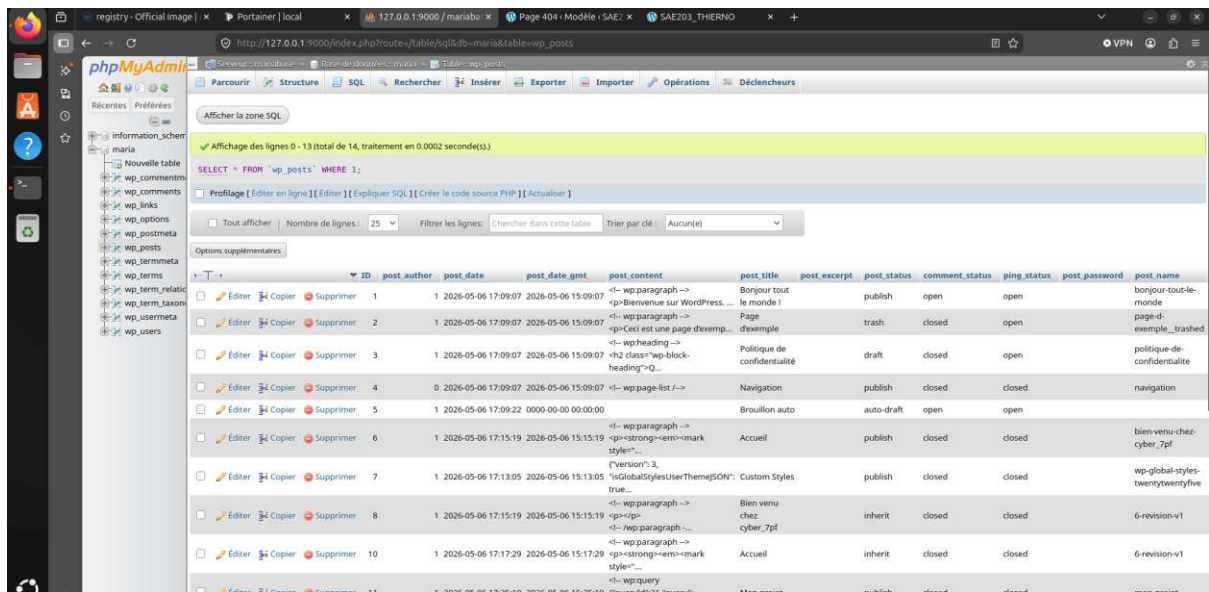
TP n°3 Wordpress et les base de données

2 Organisation du site

2.1 Création d'une page

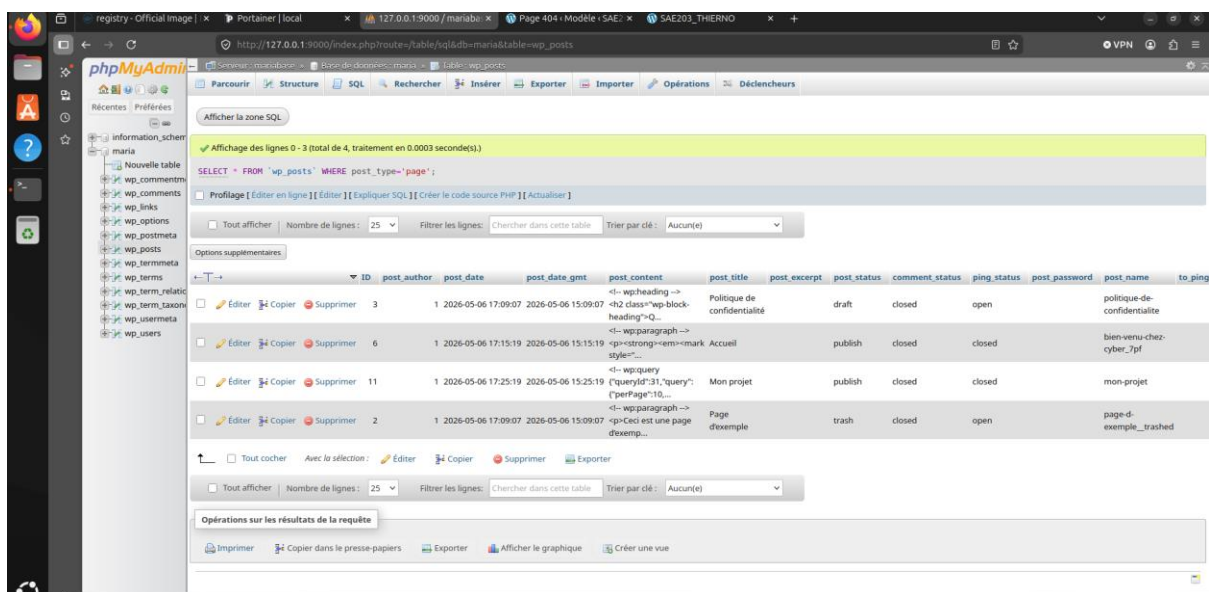


3.2 Écriture d'une requête SQL



The screenshot shows the phpMyAdmin interface with the following details:

- Database:** mariadb
- Table:** wp_posts
- SQL Query:** `SELECT * FROM 'wp_posts' WHERE 1;`
- Results:** 14 rows displayed (lines 0-13).
- Columns:** ID, post_author, post_date, post_date_gmt, post_content, post_title, post_excerpt, post_status, comment_status, ping_status, post_password, post_name.
- Row 1 (ID 1):** post_title: "Bonjour tout le monde!", post_status: "publish", comment_status: "open", ping_status: "open", post_name: "bonjour-tout-le-monde".
- Row 2 (ID 2):** post_title: "Page d'exemple", post_status: "trash", comment_status: "closed", ping_status: "open", post_name: "page-d-exemple_trashed".
- Row 3 (ID 3):** post_title: "Politique de confidentialité", post_status: "draft", comment_status: "closed", ping_status: "open", post_name: "politique-de-confidentialite".
- Row 4 (ID 4):** post_title: "Navigation", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "navigation".
- Row 5 (ID 5):** post_title: "Brouillon auto", post_status: "auto-draft", comment_status: "open", ping_status: "open", post_name: "brouillon-auto".
- Row 6 (ID 6):** post_title: "Accueil", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "bien-venu-chez-cyber_7pf".
- Row 7 (ID 7):** post_title: "wp-global-styles-twentytwentyfive", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "wp-global-styles-twentytwentyfive".
- Row 8 (ID 8):** post_title: "Bien venu chez cyber_7pf", post_status: "inherit", comment_status: "closed", ping_status: "closed", post_name: "6-revision-v1".
- Row 9 (ID 9):** post_title: "Accueil", post_status: "inherit", comment_status: "closed", ping_status: "closed", post_name: "6-revision-v1".
- Row 10 (ID 10):** post_title: "Mon projet", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "mon-projet".
- Row 11 (ID 11):** post_title: "Page d'exemple", post_status: "trash", comment_status: "closed", ping_status: "open", post_name: "page-d-exemple_trashed".



The screenshot shows the phpMyAdmin interface with the following details:

- Database:** mariadb
- Table:** wp_posts
- SQL Query:** `SELECT * FROM 'wp_posts' WHERE post_type='page';`
- Results:** 4 rows displayed (lines 0-3).
- Columns:** ID, post_author, post_date, post_date_gmt, post_content, post_title, post_excerpt, post_status, comment_status, ping_status, post_password, post_name, to_ping.
- Row 1 (ID 3):** post_title: "Politique de confidentialité", post_status: "draft", comment_status: "closed", ping_status: "open", post_name: "politique-de-confidentialite".
- Row 2 (ID 6):** post_title: "Accueil", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "bien-venu-chez-cyber_7pf".
- Row 3 (ID 11):** post_title: "Mon projet", post_status: "publish", comment_status: "closed", ping_status: "closed", post_name: "mon-projet".
- Row 4 (ID 2):** post_title: "Page d'exemple", post_status: "trash", comment_status: "closed", ping_status: "open", post_name: "page-d-exemple_trashed".

Cela n'affiche que les pages du site.

registry - Official image | x | Portainer | local | x | 127.0.0.1:9000 / mariadb: x | Page 404 - Modèle : SAE: x | SAE203_THIERNO x | +

http://127.0.0.1:9000/index.php?route=table/sql&db=mariadb&table=wp_posts

Parcourir | Structure | SQL | Rechercher | Insérer | Exporter | Importer | Opérations | Déclencheurs

Afficher la zone SQL

⚠ La sélection courante ne contient pas de colonne unique. Les grilles d'édition, les cases à cocher ainsi que les liens Éditer, Copier et Supprimer ne sont pas disponibles.

✓ Affichage des lignes 0 - 13 (total de 14, traitement en 0.0002 secondes.)

```
SELECT post_date, post_date, guid FROM 'wp_posts';
```

Profilage [Éditer en ligne] [Expliquer SQL] [Créer le code source PHP] [Actualiser]

☐ Tout afficher | Nombre de lignes: 25 | Filtrer les lignes: Chercher dans cette table | Trier par clé: Aucune(e)

Options supplémentaires

post_date	post_date	guid
2026-05-06 17:09:07	2026-05-06 17:09:07	http://127.0.0.1/?p=1
2026-05-06 17:09:07	2026-05-06 17:09:07	http://127.0.0.1/?page_id=2
2026-05-06 17:09:07	2026-05-06 17:09:07	http://127.0.0.1/?page_id=3
2026-05-06 17:09:07	2026-05-06 17:09:07	http://127.0.0.1/2026/05/06/navigation/
2026-05-06 17:09:22	2026-05-06 17:09:22	http://127.0.0.1/?p=5
2026-05-06 17:15:19	2026-05-06 17:15:19	http://127.0.0.1/?page_id=6
2026-05-06 17:18:05	2026-05-06 17:18:05	http://127.0.0.1/2026/05/06/wp-global-styles-twenty...
2026-05-06 17:18:19	2026-05-06 17:18:19	http://127.0.0.1/?p=8
2026-05-06 17:17:29	2026-05-06 17:17:29	http://127.0.0.1/?p=10
2026-05-06 17:25:19	2026-05-06 17:25:19	http://127.0.0.1/?page_id=11
2026-05-06 17:25:19	2026-05-06 17:25:19	http://127.0.0.1/?p=12
2026-05-12 14:51:37	2026-05-12 14:51:37	http://127.0.0.1/?p=13
2026-05-12 14:52:33	2026-05-12 14:52:33	http://127.0.0.1/?p=14
2026-05-12 14:55:37	2026-05-12 14:55:37	http://127.0.0.1/2026/05/12/footer/

☐ Tout afficher | Nombre de lignes: 25 | Filtrer les lignes: Chercher dans cette table | Trier par clé: Aucune(e)

Opérations sur les résultats de la requête

Imprimer | Copier dans le presse-papiers | Exporter | Afficher le graphique | Créer une vue

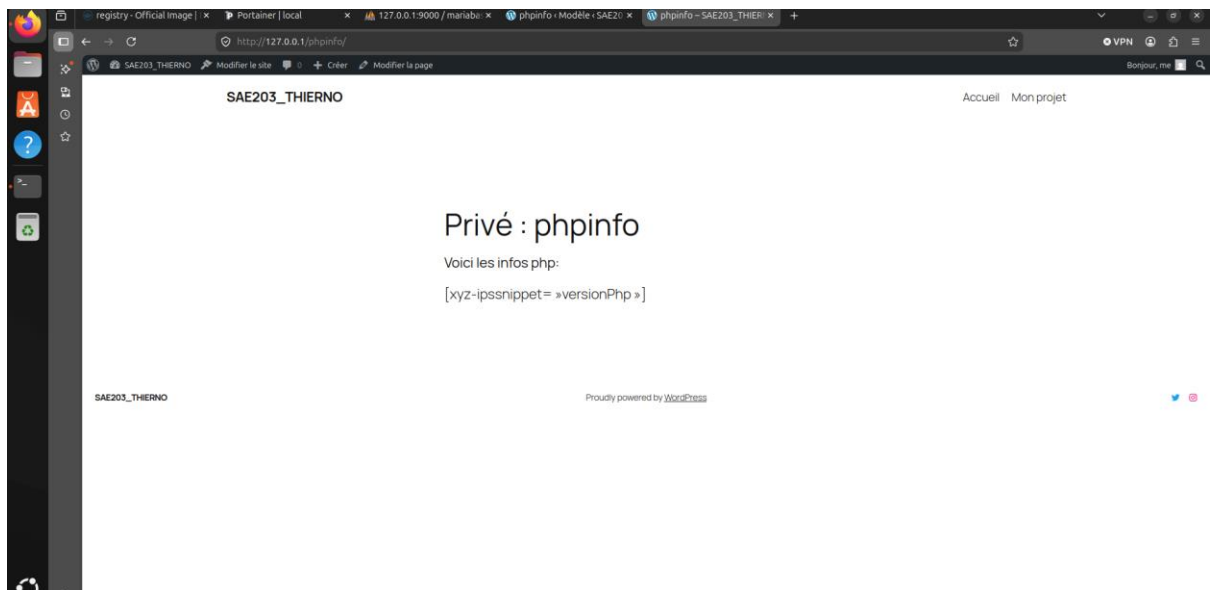
3.3 Insertion de code php dans Wordpress

The top screenshot displays the WordPress admin dashboard with the 'Insert PHP Code Snippet' plugin page open. The page title is 'Insert PHP Code Snippet' and it features a blue header with the text 'Convert your PHP code snippets to wordpress shortcodes'. The page content includes a description, installation instructions, and a list of features. The right sidebar shows the plugin's version (1.4.5), author (Tajid), and a list of reviews.

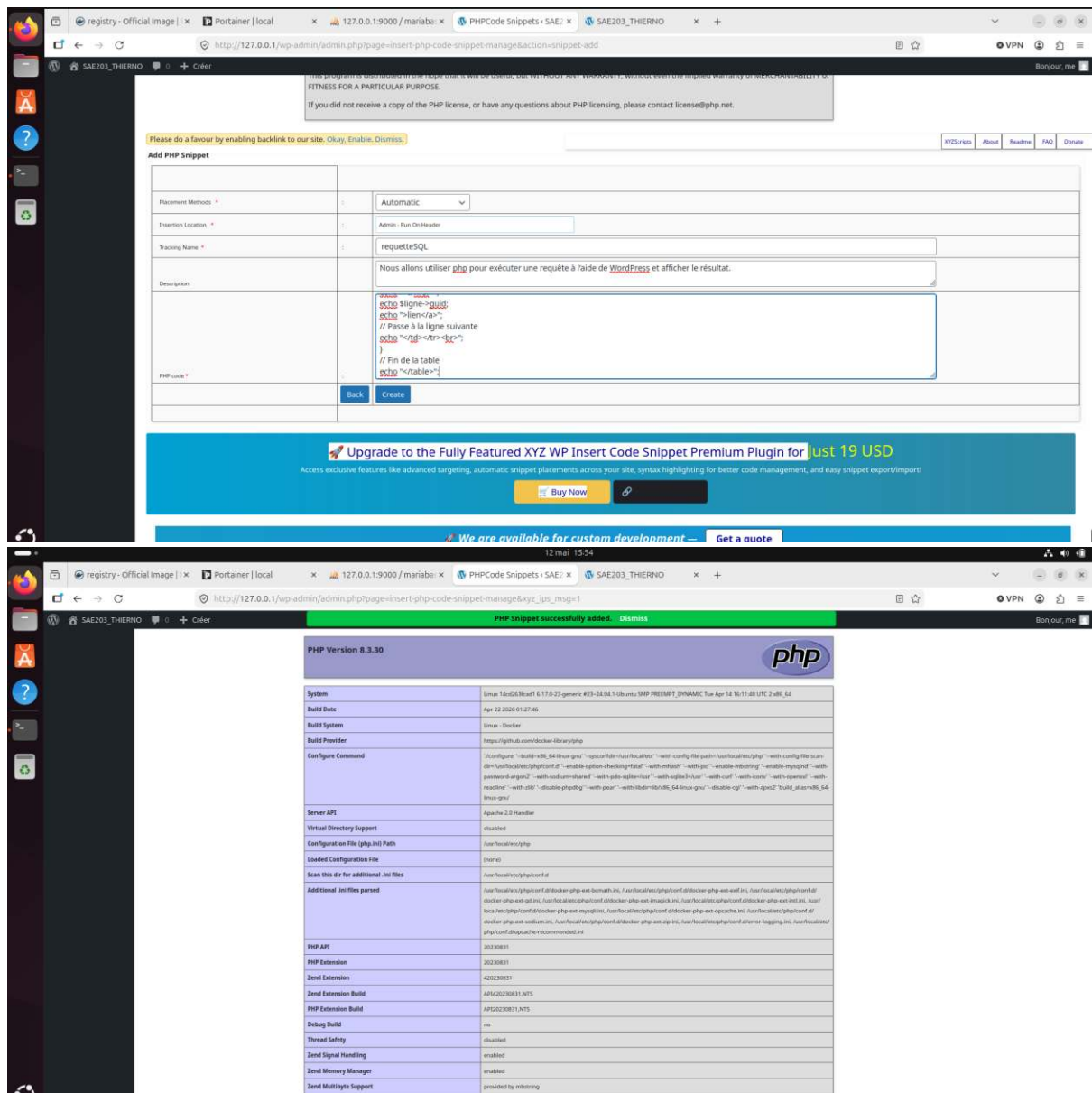
The bottom screenshot shows the 'PHP Code Snippets' management interface. It includes a 'Usage Tracking Sync Required' message, a 'Add New PHP Code Snippet' button, and a table for managing snippets. The table has columns for 'Tracking Name', 'Snippet Placement', 'Placement Details', 'Status', and 'Action'. Below the table, there is a promotional banner for the 'XYZ WP Insert Code Snippet Premium Plugin' and a section for 'Our Plugins'.

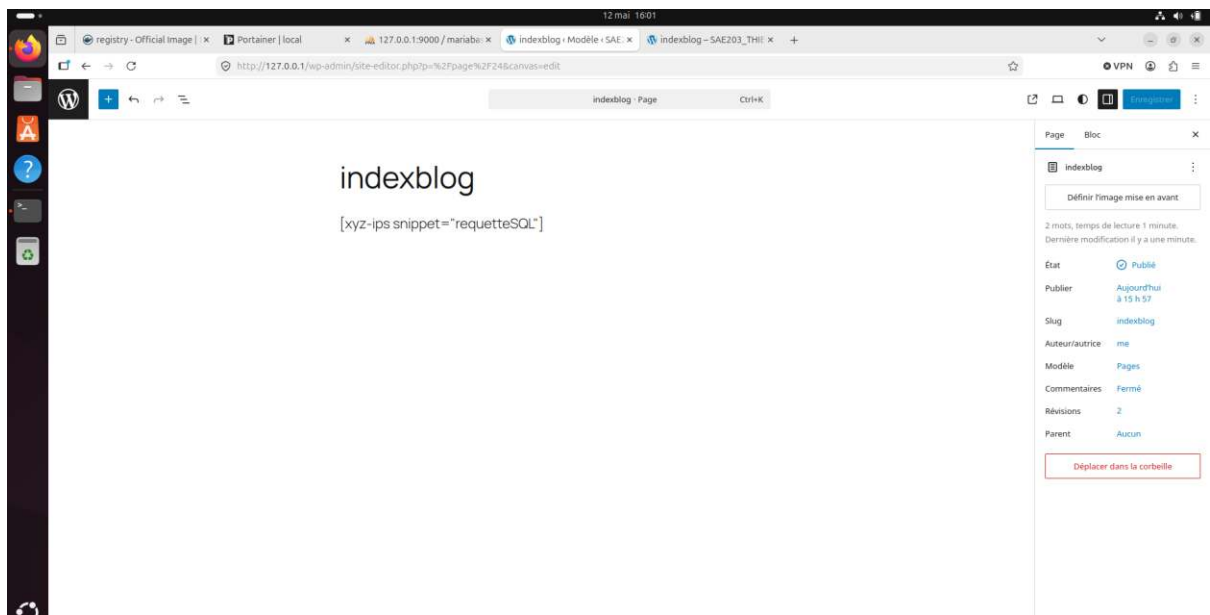
Le tracking name correspond à l'identifiant du code et le PHP code au code php à exécuter.





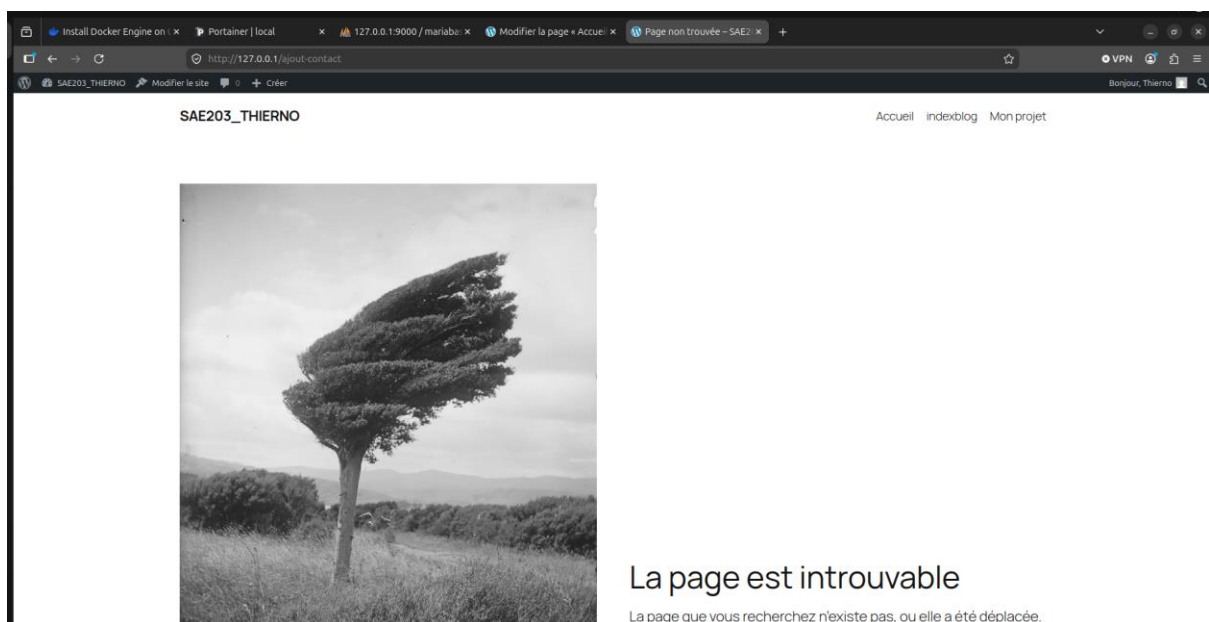
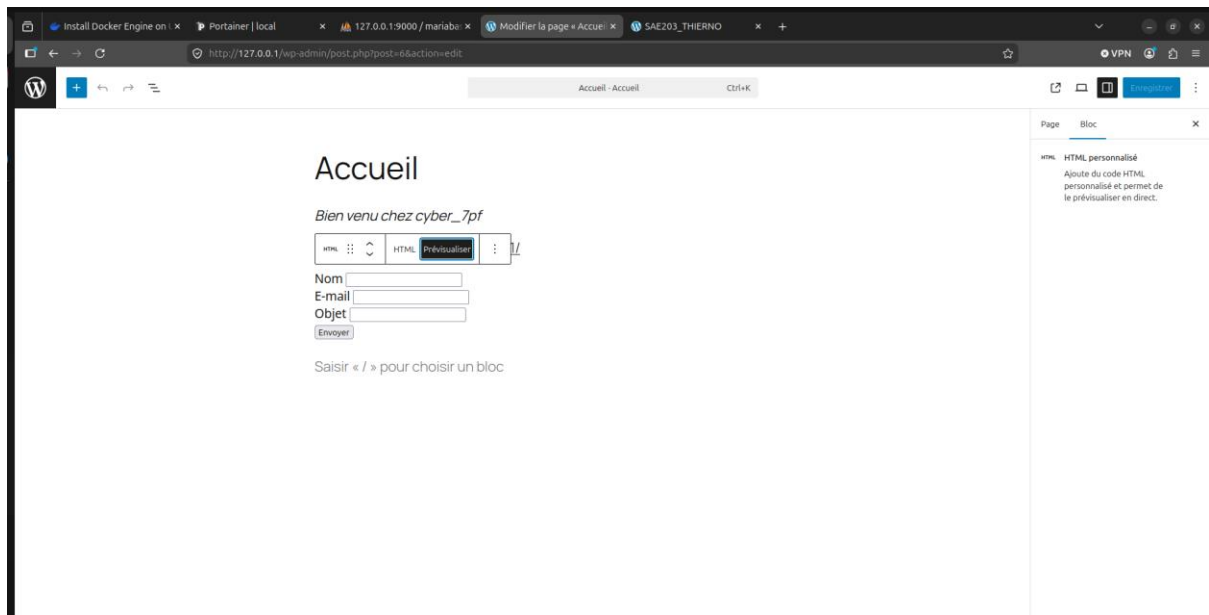
3.4 Exécuter une requête dans WordPress



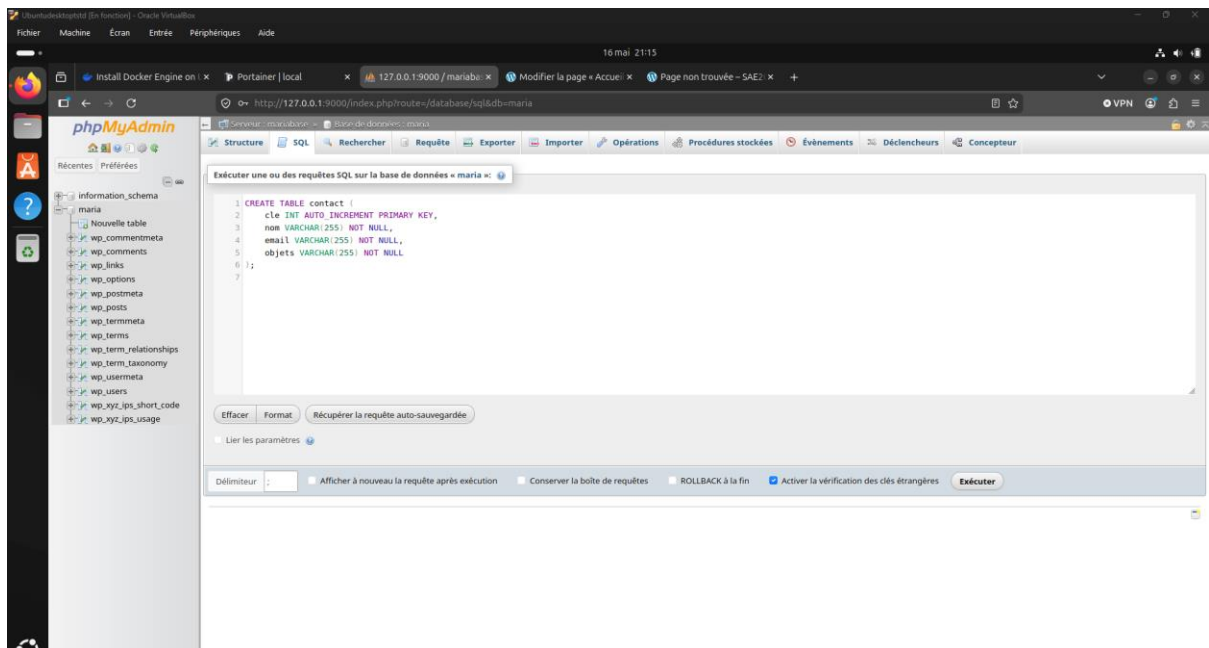


4 Création d'un page de demande de contact

4.1 Formulaire

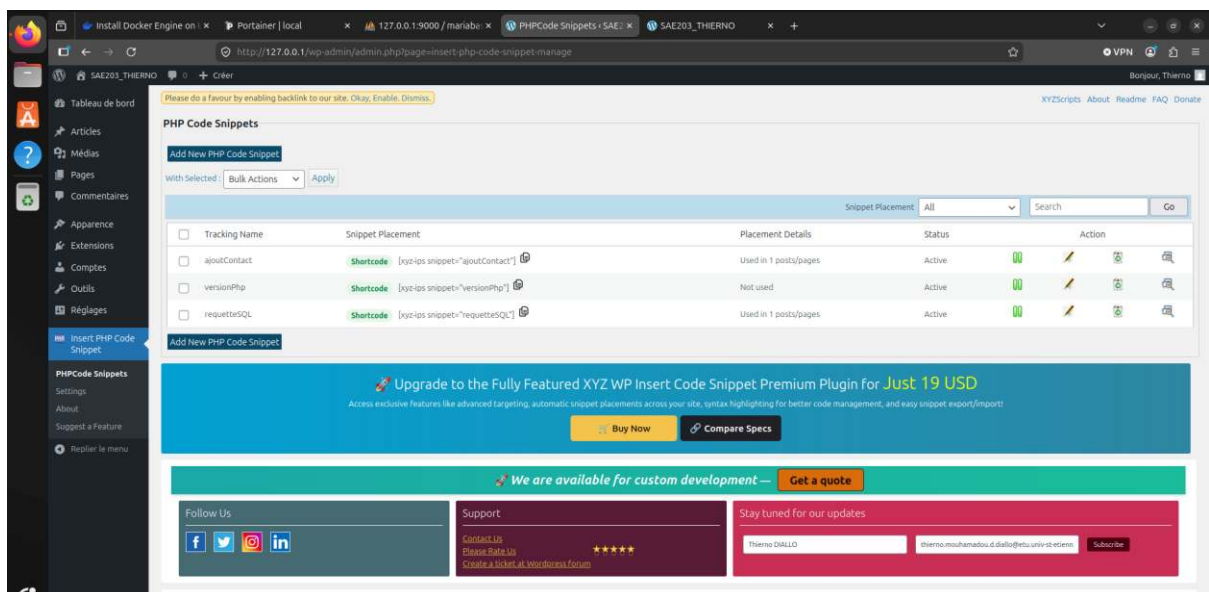


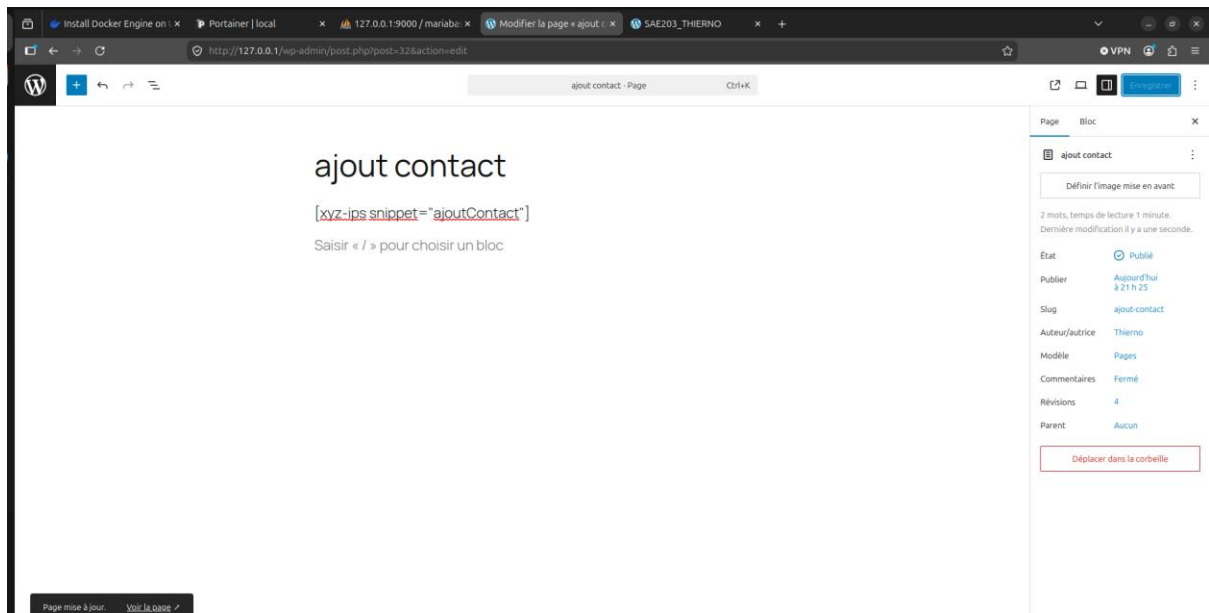
4.2 Création de la table pour stocker les données



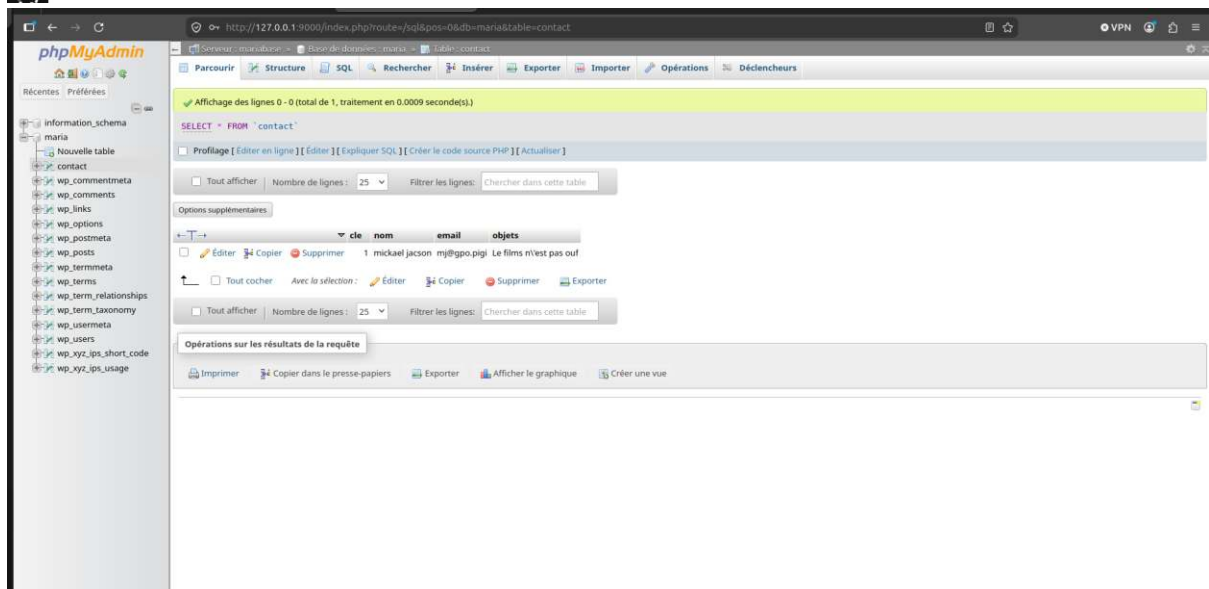
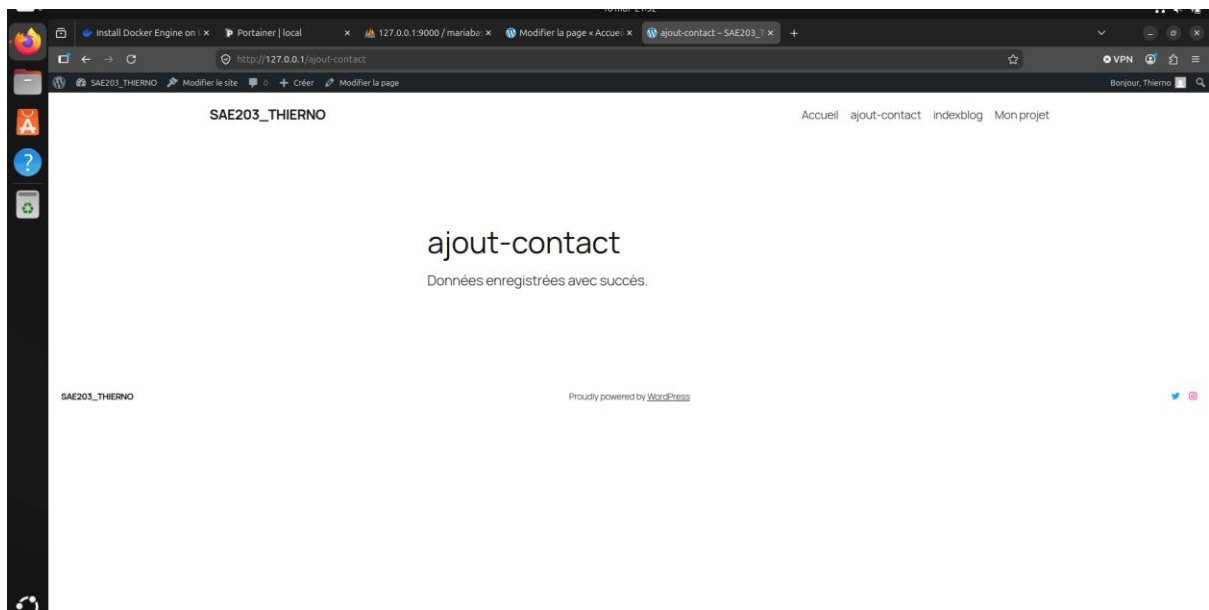
4.3 Enregistrement des données dans la table

Nous allons écrire une php snippet appelé ajoutContact dont le rôle sera de récupérer les informations saisies dans le formulaire et de les ajouter dans la base de données.

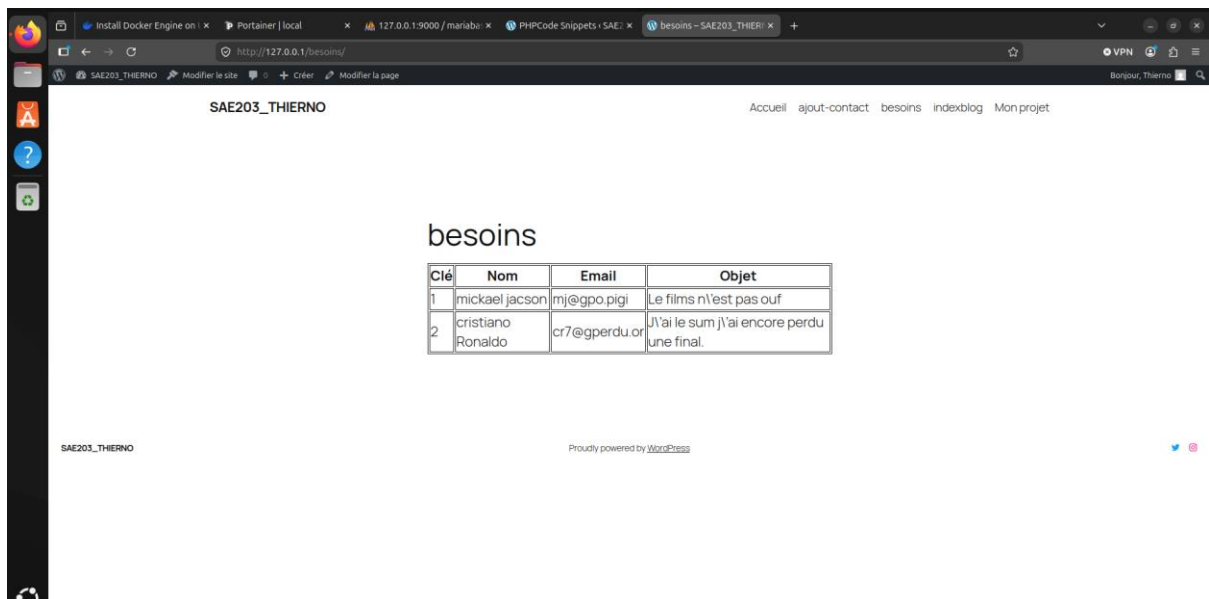




Remplissez le formulaire sur votre page d'accueil et vérifiez que lorsque vous remplissez votre formulaires les données soit bien ajoutée à votre base de données.



4.4 Affichage des données du formulaire

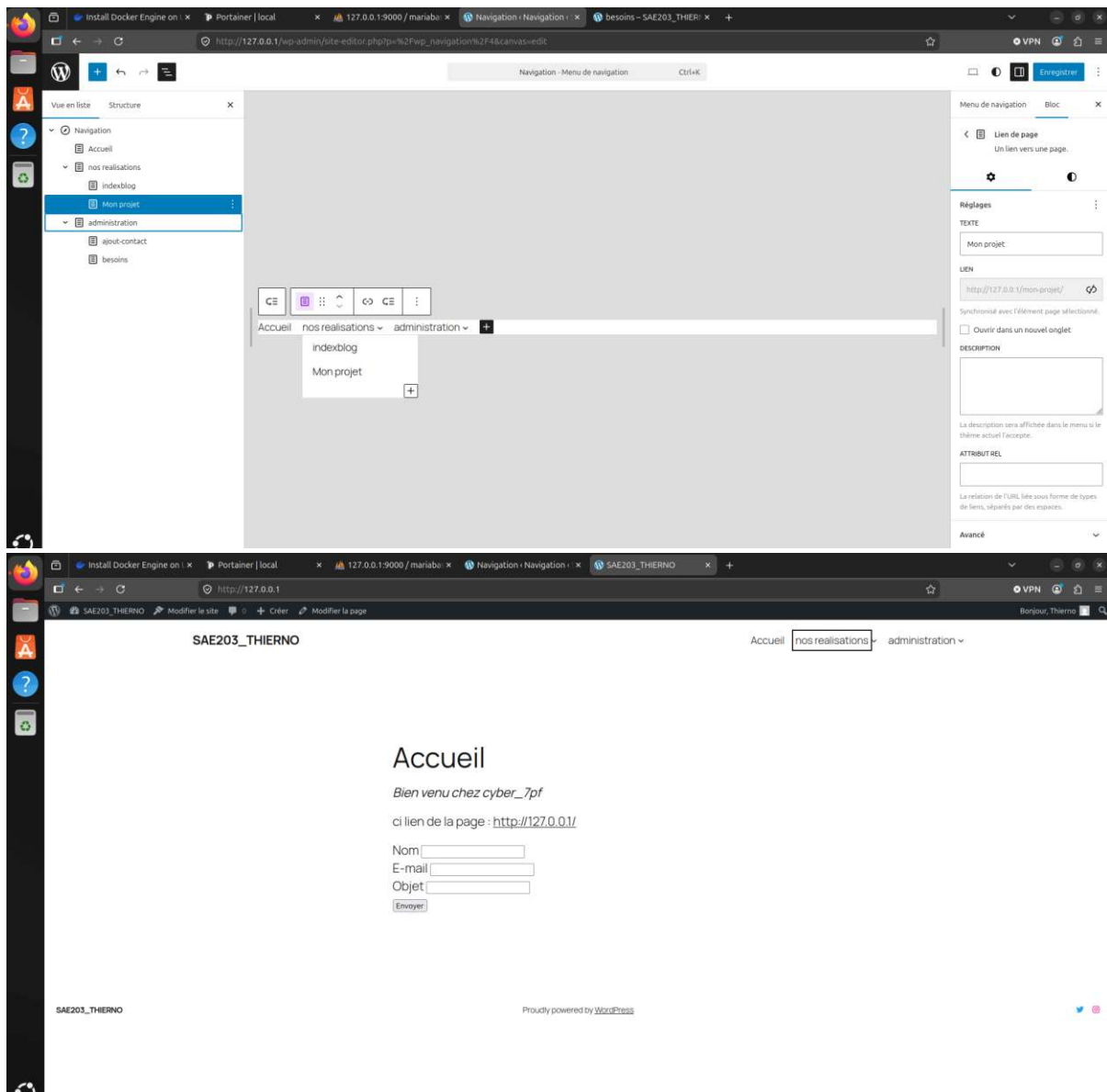


The screenshot shows a web browser window with the address bar displaying `http://127.0.0.1/besoins/`. The page title is "SAE203_THIERNO". The navigation menu includes "Accueil", "ajout-contact", "besoins", "indexblog", and "Mon projet". The main content area displays the title "besoins" followed by a table with the following data:

Clé	Nom	Email	Objet
1	mickael jacson	mj@gpo.pigi	Le films n'est pas ouf
2	cristiano Ronaldo	cr7@gperdu.or	J'ai le sum j'ai encore perdu une final.

At the bottom of the page, it says "Proudly powered by [WordPress](#)".

4.5 Réorganisation



5 Faille de sécurité

L'injection SQL permet à un attaquant d'insérer du code SQL arbitraire via les champs du formulaire de contact si les données reçues par `$_POST` sont concaténées directement dans la requête.

Utiliser la méthode `$wpdb->prepare()` de WordPress qui sépare la structure de la requête SQL des données utilisateurs en utilisant des placeholders (%s), rendant l'injection impossible.